

Arsitektur Keamanan Sistem Lost and Found

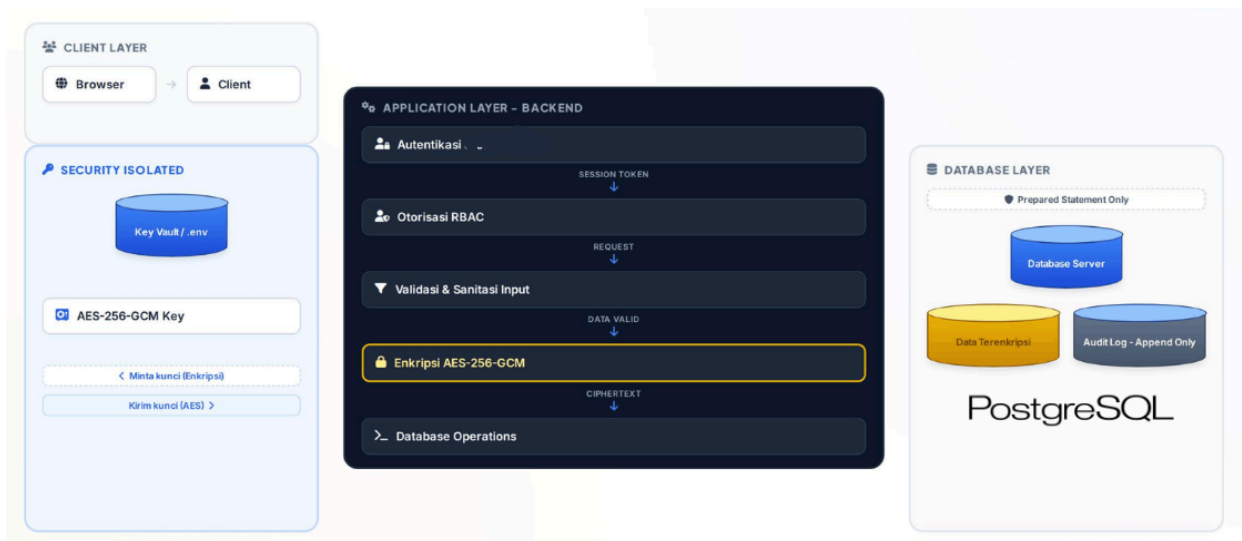
1. Ringkasan Rancangan

Berdasarkan identifikasi kelemahan pada sistem pada aplikasi Sistem Lost and Found IPB University yang masih bersifat informal dan manual, rancangan baru ini secara fundamental berfokus pada pemisahan kontrol yang ketat antara Authentication (Autentikasi), Authorization (Otorisasi), dan Accounting (Audit/Pencatatan), serta perlindungan data menyeluruh baik pada saat transit maupun saat disimpan (data at rest).

Penerapan prinsip-prinsip ini bertujuan untuk memitigasi risiko keamanan siber utama seperti *session hijacking* dan pencurian data melalui celah *SQL Injection*, sekaligus memastikan hak privasi civitas akademika IPB terlindungi sesuai standar modern arsitektur web aman.

2. Diagram Arsitektur Keamanan

Berdasarkan visualisasi diagram tata letak arsitektur sistem yang diunggah, mekanisme keamanan dibagi secara hierarkis ke dalam beberapa lapisan (layer) terisolasi yang saling berinteraksi.



A. Client Layer (Browser & Client)

Berfungsi sebagai antarmuka awal pengguna (mahasiswa atau admin). Seluruh interaksi dari lapisan ini wajib disalurkan melalui protokol komunikasi aman HTTPS (TLS) untuk mengeliminasi risiko intersepsi data di jaringan publik (sniffing).

B. Application Layer - Backend

Merupakan pusat pengendalian alur data dan logika keamanan sebelum menyentuh basis data. Lapisan ini memproses urutan validasi linear sebagai berikut:

- Autentikasi: Memvalidasi kredensial pengguna dan menerbitkan *Session Token* yang aman.
- Otorisasi RBAC (Role-Based Access Control): Memeriksa hak akses berdasarkan peran pengguna setelah menerima *Request* sesi.
- Validasi & Sanitasi Input: Menyaring seluruh data masuk guna memastikan data berstatus aman (*Data Valid*).
- Enkripsi AES-256-GCM: Mengubah data sensitif menjadi *Ciphertext* terproteksi tinggi.
- Database Operations: Mengeksekusi instruksi akhir ke lapisan penyimpanan data.

C. Security Isolated Layer (Key Vault / .env)

Lapisan isolasi mandiri yang bertugas mengelola siklus hidup AES-256-GCM Key. Kunci kriptografi disimpan terpisah dari server database utama. Mekanisme penanganan kunci bekerja secara dua arah melalui modul panggilan: *Minta kunci (Enkripsi)* dan *Kirim kunci (AES)* untuk menjamin kunci tidak terekspos dalam plain text di layer aplikasi umum.

D. Database Layer (PostgreSQL)

Lapisan penyimpanan akhir berbasis PostgreSQL yang diperketat melalui tiga komponen perlindungan langsung:

- Kebijakan eksekusi query menggunakan Prepared Statement Only untuk memitigasi serangan injeksi secara absolut.
- Pemisahan penyimpanan fisik antara blok Data Terenkripsi (Ciphertext) dan berkas Audit Log - Append Only

3. Authentication Design

Desain autentikasi dalam sistem ini menggunakan pendekatan pertahanan berlapis. Ketika pengguna memasukkan identitasnya, verifikasi tidak dilakukan pada teks sandi asli melainkan melalui pencocokan nilai hash unik. Sesi pengguna dikelola menggunakan token string acak berdensitas tinggi yang disimpan dalam cookie dengan atribut HttpOnly, Secure, dan SameSite=Strict. Atribut ini memitigasi risiko pembacaan token sesi oleh skrip berbahaya dari sisi klien (XSS) dan mencegah upaya *session hijacking*.

1. Authorization Design

Sistem menerapkan metode Role-Based Access Control (RBAC) untuk memastikan prinsip hak akses minimum (least privilege). Pengguna diklasifikasikan ke dalam peran yang kaku:

- Mahasiswa: Terbatas pada hak operasi pembuatan tiket laporan kehilangan/temuan barang miliknya sendiri, pengunggahan bukti foto, dan pelacakan status tiket.
- Admin (Civitas IPB): Memiliki hak otorisasi menyeluruh untuk melakukan inspeksi basis data tiket, memverifikasi keabsahan laporan, memperbarui status pelacakan barang, serta melakukan pencocokan silang (matching) pemilik barang.

2. Accounting dan Audit Logging

Guna mendukung aspek *Non-Repudiation* (anti-penyangkalan), sistem ini mengintegrasikan subsistem audit log dengan sifat Append-Only di dalam PostgreSQL. Setiap kali terjadi operasi modifikasi, pembacaan data sensitif, atau pergantian status barang oleh admin, sistem secara otomatis mencatat detail stempel waktu (timestamp), pengidentifikasi unik aktor, jenis operasi, dan alamat IP asal. Struktur berkas log ini dikunci sehingga tidak dapat dimodifikasi atau dihapus bahkan oleh akun aplikasi standar, melestarikan integritas data untuk kebutuhan forensik keamanan digital di masa mendatang.

IV. Arsitektur Keamanan Sistem

Berdasarkan hasil *threat modeling*, arsitektur keamanan sistem dirancang dengan tiga komponen utama, yaitu Authentication (Autentikasi Pengguna), Data Protection (Perlindungan Data), dan Database Security (Keamanan Basis Data).

A. Authentication (Autentikasi Pengguna)

Sistem autentikasi diimplementasikan dengan mekanisme login berbasis username dan password. Password pengguna tidak pernah disimpan dalam bentuk plain text, melainkan di-hash menggunakan algoritma bcrypt dengan salt acak sebelum disimpan ke basis data. Sistem juga menerapkan session management untuk menjaga status login pengguna selama sesi aktif. Penyimpanan password dilakukan menggunakan hashing bcrypt sehingga password yang tersimpan di basis data tetap terlindungi meskipun terjadi kebocoran data.

	ID	123 user_id	AZ user_role	AZ action	AZ resource	123 resource_id	AZ ip_address	AZ detail	created_at
1	1		2 mahasiswa	CREATE TICKET	tickets		10 100.64.0.2	Mahasiswa membuat tiket baru untuk barang: 'handphone'	2026-06-04 15:36:0
2	2		1 mahasiswa	LOGIN	mahasiswa		1 100.64.0.9	Mahasiswa berhasil masuk sistem	2026-06-09 00:08:3
3	3		1 admin	LOGIN	admin		1 100.64.0.12	Admin berhasil masuk sistem	2026-06-09 00:13:5
4	4		1 admin	UPDATE_TICKET_STATUS	tickets		1 100.64.0.11	Admin merubah status tiket ID 1 dari 'diproses' menjadi 'selesai'	2026-06-09 00:14:4
5	5		1 mahasiswa	LOGIN	mahasiswa		1 100.64.0.16	Mahasiswa berhasil masuk sistem	2026-06-09 00:15:2
6	6		1 mahasiswa	LOGIN	mahasiswa		1 100.64.0.12	Mahasiswa berhasil masuk sistem	2026-06-09 00:15:5
7	7		1 mahasiswa	LOGIN	mahasiswa		1 100.64.0.16	Mahasiswa berhasil masuk sistem	2026-06-09 13:26:3
8	8		1 mahasiswa	LOGIN	mahasiswa		1 100.64.0.16	Mahasiswa berhasil masuk sistem	2026-06-09 13:30:0
9	9		1 mahasiswa	LOGIN	mahasiswa		1 100.64.0.8	Mahasiswa berhasil masuk sistem	2026-06-17 19:05:5

B. Data Protection (Perlindungan Data)

Data sensitif pengguna dienkripsi menggunakan algoritma AES-GCM sebelum disimpan ke basis data. Selain itu, validasi input diterapkan pada seluruh formulir untuk mencegah data berbahaya masuk ke dalam sistem. Komunikasi antara klien dan server menggunakan HTTPS untuk melindungi data selama proses transmisi.

Enkripsi data saat penyimpanan (*data at rest*) menggunakan AES-GCM 256-bit untuk melindungi data identitas pelapor, informasi kontak, dan deskripsi barang. Pada proses ini juga dihasilkan *Authentication Tag* untuk memastikan integritas data. Sementara itu, enkripsi data saat transmisi (*data in transit*) dilakukan menggunakan HTTPS untuk seluruh komunikasi antara klien dan server. Seluruh input pengguna juga disanitasi dan divalidasi sebelum diproses oleh sistem

C.Database Security (Keamanan Basis Data)

Keamanan basis data diterapkan untuk melindungi data dari manipulasi dan akses yang tidak sah. Seluruh query basis data menggunakan Prepared Statement atau ORM (Object-Relational Mapping) untuk mencegah serangan SQL Injection.

Pencegahan SQL Injection dilakukan melalui penggunaan Prepared Statement atau ORM secara konsisten pada seluruh operasi basis data. Selain itu, sistem menerapkan prinsip *least privilege*, yaitu akun basis data yang digunakan aplikasi hanya diberikan hak akses minimum yang diperlukan untuk menjalankan fungsinya tanpa eksposur administratif yang berlebihan.

